

CODEALPHA

Cyber Security Internship

TASK 2

Phishing Awareness Training

By: Ayat Zahra

Recognizing Phishing Emails, Fake Websites & Social Engineering

Prepared as part of the CodeAlpha Cyber Security Internship Program

www.codealpha.tech

1. Objective

Design and deliver a phishing-awareness training module that teaches non-technical users to recognize phishing emails and fake websites, understand the social-engineering tactics behind them, and apply simple, memorable habits that stop an attack before it succeeds.

Learning Goals

- Understand what phishing is and why it remains the most common entry point for cyberattacks.
- Learn to visually and mentally flag the warning signs in an email or website.
- Recognize the psychological tactics (urgency, authority, fear) attackers rely on.
- Build a short, reusable checklist and quiz that can be delivered to real users.

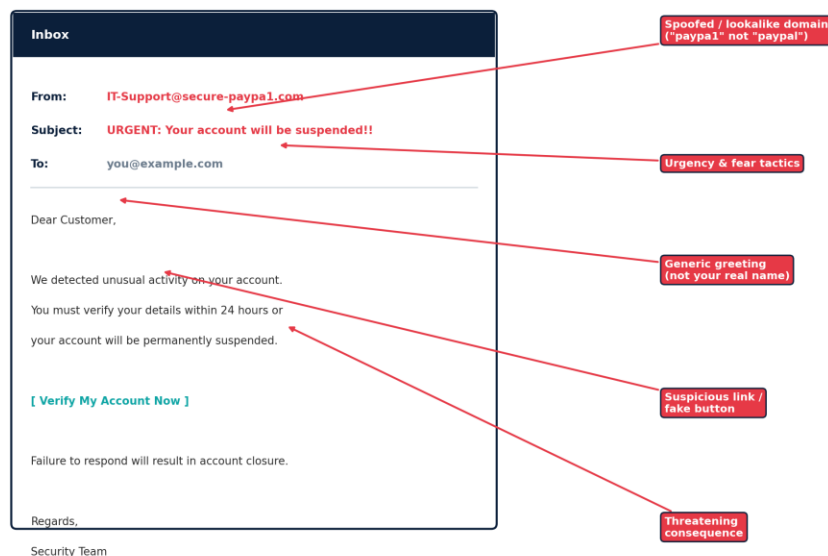
2. What Is Phishing?

Phishing is a social-engineering attack in which someone impersonates a trusted person, brand, or system — usually by email, text message, or phone — to trick a target into revealing credentials, payment details, or other sensitive information, or into installing malware. It succeeds by exploiting human trust and urgency rather than a technical vulnerability, which is why awareness training is one of the most effective defenses an organization can deploy.

The average user receives dozens of emails a day; a phishing message only needs to fool them once. Training shifts the odds by turning “I didn’t notice” into “I checked, and it didn’t add up.”

3. Recognizing Phishing Emails & Fake Websites

Most phishing messages share a recognizable pattern once you know what to look for: a mismatched sender address, invented urgency, a generic greeting, a suspicious link, and a threat if you don’t act. The annotated example below walks through each red flag.

Fig 1. Anatomy of a Phishing Email*Figure 1 — A typical phishing email with its warning signs highlighted.*

Quick Red-Flag Checklist

- Sender domain is misspelled, slightly altered, or doesn't match the real company (paypa1.com vs paypal.com).
- Greeting is generic ("Dear Customer") instead of your actual name.
- Message creates urgency or fear ("act within 24 hours or lose access").
- Link text doesn't match where it actually leads — hover before you click.
- Unexpected attachment, especially .exe, .zip, or macro-enabled Office files.
- Poor grammar, awkward phrasing, or a logo that looks slightly off.
- Request for passwords, OTPs, or payment that a real company would never ask for by email.

Fake websites use the same tricks at the browser level. Always read the full domain name before entering credentials — attackers rely on people glancing at a URL rather than reading it carefully.

Fig 4. Spot the Fake — Reading a URL Before You Click*Figure 4 — A legitimate domain versus a lookalike phishing domain.*

4. Types of Phishing Attacks

Phishing isn't a single technique — attackers adapt the delivery channel and level of personalisation to the target.

Fig 2. Common Types of Phishing Attacks

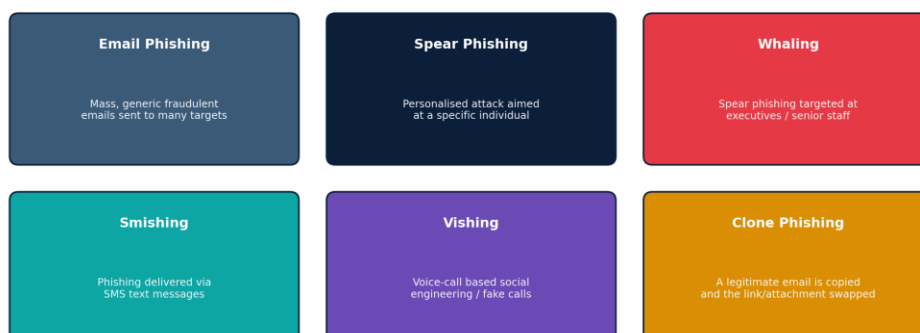


Figure 2 — The most common categories of phishing attacks.

5. Social Engineering Tactics

Every phishing message leans on one or more psychological levers. Recognising the lever being pulled is often faster than analysing the technical details of a message.

Fig 3. Social Engineering Tactics Used by Attackers



Figure 3 — The core psychological tactics behind social engineering attacks.

6. Best Practices & Tips

- Pause before clicking — legitimate deadlines are rarely a matter of hours.
- Hover over links (or long-press on mobile) to preview the real destination before tapping.
- Verify unexpected requests through a separate, known channel — call the company using the number on their official site, not the one in the email.
- Never enter credentials after clicking an email link; navigate to the site directly instead.
- Enable multi-factor authentication (MFA) everywhere it's offered, so a stolen password alone isn't enough.
- Report suspicious emails to IT/security rather than just deleting them — one report can protect the whole organisation.
- Keep browsers and email clients updated so built-in phishing filters stay effective.

7. Real-World Style Examples

The following illustrative scenarios (not tied to any real company) reflect patterns commonly seen in phishing reports:

Scenario	Red Flag
"Your package couldn't be delivered — pay a ₹50 customs fee to reschedule."	Unsolicited fee request with a countdown timer and a shortened link.
"Your manager needs you to buy 5 gift cards urgently, reply ASAP."	Impersonation of authority + urgency, sent from a look-alike free email address.
"Unusual sign-in detected — confirm your password to secure your account."	Real companies link to your account settings; they never ask you to type your password into an email.
"Congratulations! You've won a prize — claim within 1 hour."	Reward-based bait with an artificial deadline designed to stop rational thinking.

8. Interactive Quiz

A short quiz reinforces the training and can be delivered as a live poll or embedded in an LMS module.

#	Question	Answer
1	An email urges you to "verify your account within 1 hour or lose access." What should you do first?	Do not click — navigate to the site directly or contact support through a known channel.
2	True or False: A padlock icon in the browser means a site is 100% safe.	False — it only means the connection is encrypted, not that the site is legitimate.

#	Question	Answer
3	You get a text from your “bank” asking you to confirm your PIN by reply. What's wrong?	Banks never request PINs or passwords via text — this is smishing.
4	Which detail most reliably exposes a fake sender address?	The actual domain after the @ symbol, not the display name shown.
5	Your CEO emails asking you to urgently wire funds, but the tone feels off. Best action?	Verify by phone or in person before acting — classic whaling / BEC pattern.

9. Conclusion & Learning Outcomes

Delivering this training builds the habits that stop phishing before it reaches a technical control: pausing on urgency, verifying senders and links, and reporting suspicious messages. These same recognition skills carry directly into the workplace and into every other security awareness effort.

- Ability to identify the core red flags of a phishing email or website.
- Understanding of the different phishing delivery channels and their relative risk.
- Familiarity with the social-engineering psychology attackers exploit.
- A ready-to-use checklist and quiz suitable for training real end-users.

References

CISA Phishing Guidance — cisa.gov/topics/cyber-threats-and-advisories/phishing • Anti-Phishing Working Group — apwg.org